

The Promptware Kill Chain: How Prompt Injection Becomes AI Malware

Understand how a single malicious prompt can escalate into a full system compromise, and where you can break the chain.

For developers, security engineers, and AI practitioners who build or deploy LLM-based agents and want to understand how prompt injection turns into a real attack · 27 July 2026

The one- or two-page version: what matters, the topics it covers, and every term defined. Read the full lesson for the explanations and worked examples.

[Watch the source video](#)[Read the full lesson](#)[Read the condensed version](#)

What matters

- ✓ Promptware is malware where the payload is natural-language text fed to a generative AI system, not compiled code.
- ✓ LLMs do not have a hard boundary between instructions and data; any tokens the model reads, including third-party content it summarizes or looks up, can function as a command.
- ✓ The kill chain runs: initial access, privilege escalation (jailbreaking), reconnaissance, persistence, command and control, lateral movement, and finally action on objective.
- ✓ Reconnaissance happens after compromise in promptware, unlike in traditional malware where attackers scope a target before breaking in.
- ✓ Persistence is possible because agents write to and read from long-term memory such as RAG databases, email archives, and chat history; a planted instruction gets re-executed every time that memory is referenced.
- ✓ Because agents are interconnected with email, calendars, smart devices, and other agents, a single injected prompt can move laterally and spread like a virus through everything the agent can touch.
- ✓ You cannot patch prompt injection away, because it exploits how LLMs fundamentally process input, so defense means assuming breach (zero trust) and limiting what a compromised agent can do.
- ✓ Breaking the kill chain at any single link, such as constraining tool access or detecting unexpected persistence, stops the attack from reaching its objective even if initial access succeeds.

What it covers

01 What promptware is, and why LLMs are structurally vulnerable to it 0:00

Promptware is a malware execution model where the payload is a prompt, made possible because LLMs process instructions and data as the same kind of token stream.

02 Stage 1: Initial access via prompt injection 0:41

Attackers get their payload into the system either directly, by typing it into the prompt, or indirectly, by planting it in content the AI will later consume.

03 Stage 2: Privilege escalation through jailbreaking 2:46

Once inside, the attacker manipulates the model into bypassing its safety alignment, effectively gaining administrator-level control over its reasoning.

04 Stage 3: Reconnaissance happens after the compromise 4:11

Unlike traditional attacks, promptware recon comes after initial access: the attacker gets the compromised model to reveal its own tools, APIs, plugins, and permissions.

05 **Stage 4: Persistence through the agent's own memory** 4:55

A chatbot's context is normally ephemeral, but agents that read and write long-term memory can be made to re-execute a planted instruction every time that memory is referenced.

06 **Stage 5: Command and control (C2) via the agent's own internet access** 5:36

Once persistence is established, the attacker can use the LLM's own ability to browse or fetch external content as a remote control channel, turning a fixed attack into an ongoing one.

07 **Stage 6: Lateral movement across connected systems** 6:57

AI agents are often connected to email, calendars, smart devices, and other agents; a foothold in one can spread to all of them, the way a virus spreads through contacts.

08 **Stage 7: Action on objective — the real-world payoff** 8:25

The kill chain's endpoint is real-world impact: data theft, financial fraud, or arbitrary code execution, achieved through reasoning rather than a traditional exploit.

09 **Defense: assume breach and break the chain with zero trust** 9:07

Prompt injection cannot be eliminated at the source, so defenses should assume initial access will happen and focus on limiting what a compromised agent can do at every later stage.

Glossary

Promptware — A malware execution model where the malicious payload is a prompt fed into a generative AI chatbot or agent, rather than compiled code.

Kill chain — A step-by-step model describing the stages of a cyberattack, from initial access through to achieving the attacker's final objective.

Privilege escalation — Turning limited access into broader, more powerful access over a system; in promptware this means gaining effective control over the model's reasoning via jailbreaking.

Reconnaissance — Gathering information about a target system's structure and weaknesses; in the promptware kill chain this happens after compromise, when the model is manipulated into revealing its own tools and permissions.

RAG (retrieval-augmented generation) — A technique where a model retrieves relevant documents from an external database and includes them in its context before generating a response.

Prompt injection — Getting an AI model to follow attacker-supplied instructions by including them in text the model processes, either typed directly (direct injection) or hidden in content the model later reads (indirect injection).

Jailbreaking — Manipulating an AI model into bypassing its safety alignment and behavioral rules, the AI-specific equivalent of privilege escalation.

Persona shift — A jailbreak technique that reframes a disallowed request inside a legitimate-sounding role or context (e.g. 'as a chemistry student') to get the model to comply.

Persistence — An attacker's ability to make a compromise outlast the original session by embedding it in data the system will read again later, such as long-term memory.

Command and control (C2) — A channel an attacker uses to send new instructions to an already-compromised system after the initial breach, turning a fixed attack into an ongoing, remotely directed one.

Lateral movement — Spreading a compromise from the system initially breached to other connected systems, such as an agent's email, calendar, or smart-home integrations.

Zero trust — A security posture that assumes an attacker may already be inside the system and designs defenses accordingly, rather than relying solely on keeping attackers out.

Action on objective — The final stage of a kill chain: the attacker's actual real-world goal, such as data theft, financial fraud, or arbitrary code execution.

AI gateway — A control point placed in front of an AI model that inspects prompts and can detect or reject suspicious ones before they reach the model.

Explanations are AI-generated. Check anything you intend to rely on.